

Request for Proposal (RFP): CERT-In & FIU-IND Compliance Cyber Audit Certificate

1. Project Objective

Arab Global is seeking a qualified cybersecurity auditing firm—must be a **CERT-In Empaneled Auditor**—to conduct a dual-scope assessment. The objective is to verify compliance with **CERT-In Direction 70B** and **FIU-IND / PMLA (2002)** guidelines for Virtual Digital Asset Service Providers (VDA SPs) & get onboarded as Registered Entity with Financial Intelligence Unit (FIU) India

2. Detailed Scope of Work

Part A: CERT-In Direction 70B Compliance

The auditor shall evaluate the technical and operational alignment with the latest CERT-In mandates, focusing on:

- **Log Management:** Verification of log retention policies for a rolling **180-day period** stored within Indian jurisdiction.
- **Time Synchronization:** Audit of Network Time Protocol (NTP) configurations to ensure synchronized time across all infrastructure.
- **Incident Response:** Review of internal workflows to meet the **6-hour mandatory reporting window** for cybersecurity incidents.
- **Infrastructure & Cloud Security:** Security configuration audit of cloud-native environments and internal network architecture.
- **Application & API Security:** Vulnerability Assessment and Penetration Testing (VAPT) of all web/mobile applications and API endpoints used for VDA trading.

Part B: FIU-IND & PMLA Compliance

The auditor shall assess the Anti-Money Laundering (AML) and Countering the Financing of Terrorism (CFT) framework:

- **KYC/KYB Evaluation:** Audit of onboarding processes for individuals and entities to ensure "Know Your Customer/Business" adequacy.
- **Transaction Audit:** Comprehensive review of both **Financial (Fiat)** and **Blockchain (On-chain)** transaction records.
- **Monitoring & Reporting:** Audit of the **Transaction Monitoring System (TMS)** and the ability to generate/file Suspicious Transaction Reports (STRs), Cash Transaction Reports (CTRs), and NTRs.
- **Governance & Training:** Review of the AML/CFT Policy, risk assessment matrices, and evidence of mandatory employee AML training.

3. Audit Methodology & Governance

- **Evidence Collection:** The auditor must perform walkthroughs, configuration reviews, and sample-based testing of transaction logs.
- **Data Sovereignty:** Ensure the audit confirms that data residency requirements per Indian law are strictly followed.
- **Risk Categorization:** Findings must be mapped to a risk matrix (Critical/High/Medium/Low).

4. Required Deliverables

1. **Gap Analysis Report:** Initial findings and required remediation steps.
2. **Final Audit Report:** A detailed technical and regulatory report for both CERT-In and FIU-IND scopes.
3. **Attestation of Compliance (AoC):** A formal certificate or letter of attestation for submission to regulatory bodies.
4. **Executive Summary:** A high-level brief for the Board and Management.

5. Auditor Requirements

- **Accreditation:** Must be a **CERT-In Empaneled Security Auditing Organization**.
- **VDA Expertise:** Proven track record of auditing Crypto Exchanges or Virtual Digital Asset providers.
- **Regulatory Knowledge:** Deep familiarity with the **Prevention of Money Laundering Act (PMLA), 2002** and FIU-IND reporting portals.